PRADITA University

IT40613 · Digital Platform & API Economy

Manajemen Siklus Hidup API dan API Gateway

Pertemuan 10

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. Siklus Hidup API
3. Versi dan Deprecation
4. API Gateway
5. Platform Manajemen API
6. Memilih Platform
7. Gateway dan Service Mesh
8. Aktivitas
9. Ringkasan
10. Latihan

PRADITA University

12 klinik masih di versi lama.
Ditutup: 720 pemesanan gagal.
Dibiarkan: Rp45 juta setahun.
Siapa yang memutuskan?

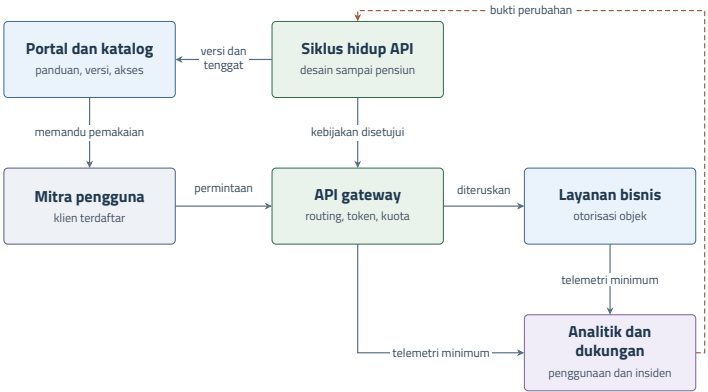
Tujuan Pembelajaran

PRADITA University

- Menjelaskan tahap siklus hidup API dan keputusan penting di tiap tahap.
- Menjelaskan fungsi *API gateway* dan komponen platform manajemen API.
- Membandingkan alternatif platform manajemen API dengan kriteria yang dapat dipertanggungjawabkan.

Diagram Konsep Bab 10

Gateway dan pengelolaan siklus hidup API



Portal mendukung pengguna; gateway menjalankan kebijakan lalu lintas; pemilik API mengelola perubahan dan migrasi versi.

Masukan dari Bab Sebelumnya

Asal	Temuan yang dipakai	Kegunaan di sini
Bab 4	Lapisan bersama Rp300 juta per tahun, Rp45 juta per antarmuka	Pagu platform
Bab 5	Rantai pemesanan 99,40 persen, 168 gagal per bulan	Dampak *gateway*
Bab 6	Register RA-01 sampai RA-07, kuota 300 per hari, 444.000 catatan	Kebijakan di *gateway*
Bab 8	40 klinik, tim 7.680 jam, cadangan 1.080 jam	Kapasitas operasi
Bab 9	Kontrak API-01, Two in Production, alamat `/v2`	Masa transisi

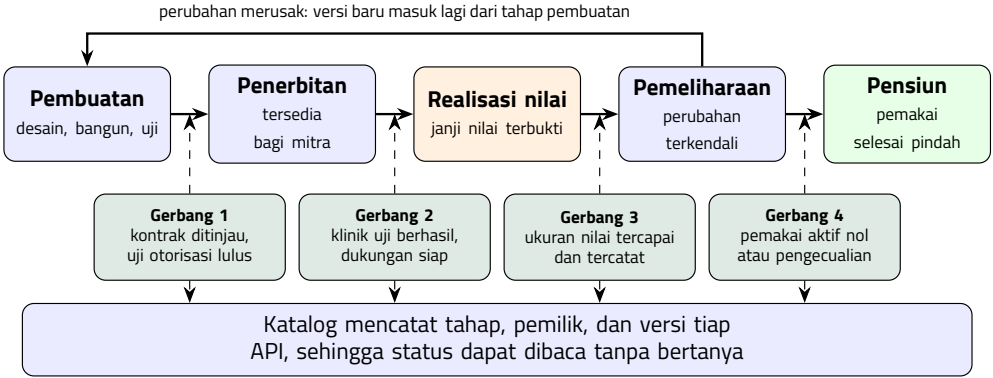
Tarif Rp60.000 per jam, 20 sambungan aktif Rp900 juta per tahun. Vendor Medikara+ butuh 4 bulan.

Lima Tahap Siklus Hidup

- Rangkaian tahap yang dilalui satu API sejak gagasan sampai dihentikan.
- Medjaoui dkk.: *create*, *publish*, *realize*, *maintain*, *retire*.
- Bab ini: pembuatan, penerbitan, realisasi nilai, pemeliharaan, pensiun.
- Setiap perpindahan memerlukan bukti yang sesuai risikonya.
- Status API harus terlihat di katalog.

Analogi: kendaraan dinas tetap membayar pajak sampai surat penghapusannya selesai.

Empat Gerbang Bukti



Keputusan Penting di Tiap Tahap

Tahap	Keputusan penting	Bukti pada API-01
Pembuatan	Layak dibangun, isi kontrak	Kanvas Bab 8, kontrak Bab 9, uji otorisasi objek
Penerbitan	Siapa boleh memakai, kapan	5 klinik uji berhasil, dukungan dan rencana cadangan siap
Realisasi nilai	Apakah janji nilai terbukti	Telepon konfirmasi dari 240 ke 48 per hari
Pemeliharaan	Perubahan mana dikerjakan	Tiga gerbang Bab 9, 12 usulan dengan kapasitas 6
Pensiun	Kapan dihentikan, apa gantinya	Pemakai aktif nol. Pemicu: klinik aktif di bawah 30

Dua Contoh Berangka

- API-02 tidak terbit hanya karena kode selesai. Misalkan tinjauan 5 orang, 2 jam: Rp600.000.
- Satu kredensial bersama bocor: 40 klinik, 2 jam, Rp4,8 juta, atau 8 kali tinjauan.
- Misalkan antarmuka yang tidak dipakai dibiarkan 3 tahun: Rp135 juta.
- OWASP: penyerang biasanya masuk lewat versi lama tanpa tambalan.
- Empat gerbang: Rp2,4 juta per API, atau Rp7,2 juta untuk tiga API.

Tingkat Kematangan: API-m-FAMM

PRADITA University

Area fokus	Kapabilitas	Keadaan Medikara (pemisalan)
Lifecycle Management	Versi, pemisahan, pemberitahuan	Belum ada API mitra dan kebijakan versi
Security	Autentikasi, otorisasi, ancaman, enkripsi	Register RA-01 sampai RA-07 sudah ada
Performance	Sumber daya, lalu lintas	Kuota 300 masih rancangan
Observability	Pemantauan, pencatatan, analitik	Catatan rinci 7 hari pada kasus insiden
Community	*Onboarding*, dukungan, dokumentasi	Belum ada portal mitra
Commercial	SLA, monetisasi, akun	Rp3 juta per klinik per bulan masih usulan

6 area, 20 kapabilitas, 80 praktik. Baca per area, seperti rapor per mata pelajaran. Kematangan bukan jumlah fitur *gateway*.

Versi dan Deprecation

- Versi menjelaskan kontrak yang didukung.
- *Deprecation*: kontrak tidak lagi dianjurkan dan akan dihentikan.
- RFC 9745: perilaku API tidak berubah oleh *deprecation*.
- Kebijakan: alasan, jadwal, pengganti, cara menguji, bantuan migrasi.
- Versi baru tidak membebaskan penyedia dari komunikasi kepada pemakai lama.

Analogi: nomor telepon layanan lama tetap tersambung selama masa pengalihan.

Yang Sering Tertukar: Deprecation dan Sunset

PRADITA University

Keadaan	Arti	Perilaku versi 1	Tanda
Didukung	Kontrak berlaku penuh	Menjawab seperti kontrak	Status di katalog
Deprecation	Tidak dianjurkan, pengganti tersedia	Tetap menjawab, klinik baru tidak diterima	*Header* `Deprecation`, surel, portal
Sunset	Dihentikan pada waktu yang diumumkan	Sesudahnya menjawab 410	*Header* `Sunset`, kode 410

RFC 8594: waktu *sunset* adalah petunjuk. RFC 9745: waktu *sunset* tidak boleh lebih awal daripada *deprecation*.

Dua Contoh Berangka

- Misalkan 12 klinik belum pindah saat ditutup: 720 pemesanan gagal per hari.
- Telepon 3 menit: 36 jam, Rp2,16 juta per hari.
- Versi lama sebulan lagi: Rp3,75 juta, setara kurang dari 2 hari penutupan keliru.
- Tenggat 3 bulan bukan aturan universal. Vendor Medikara+ butuh 4 bulan.
- Sebulan tanpa API: 28.000 janji temu, 1.400 jam, Rp84 juta.

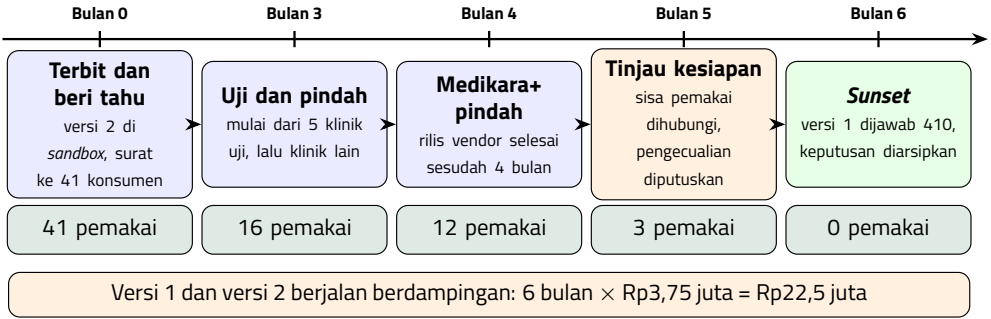
Pola Masa Hidup Versi

PRADITA University

Pola	Janji kepada pemakai	Pada Medikara
Experimental Preview	Boleh mencoba, tanpa jaminan	Versi 2 untuk 5 klinik uji
Two in Production	Dua versi berdampingan	Rp3,75 juta per bulan
Limited Lifetime Guarantee	Tanggal berakhir diketahui	Tertulis di perjanjian
Aggressive Obsolescence	Klien dipaksa berhenti	Hanya pengecualian keamanan

- Tidak ada angka baku. GitHub: paling sedikit 24 bulan.
- Zalando: persetujuan klien, kesepakatan rentang waktu, pemantauan pemakaian.
- Medikara: 41 konsumen dengan kontak. Dasarnya konsumen paling lambat.

Linimasa Masa Transisi API-01



Kasus Medikara: Tiga Pilihan Lama Transisi

Unsur	3 bulan	6 bulan	12 bulan
Dua versi berjalan, Rp3,75 juta per bulan	Rp11,25 juta	Rp22,5 juta	Rp45 juta
Medikara+ belum siap, Rp84 juta per bulan	Rp84 juta	Rp0	Rp0
Migrasi, 240 jam	Rp14,4 juta	Rp14,4 juta	Rp14,4 juta
Jumlah	**Rp109,65 juta**	**Rp36,9 juta**	**Rp59,4 juta**

Keputusan Bab 10: 6 bulan, yaitu vendor 4 bulan, uji bersama 1 bulan, dan cadangan 1 bulan. Inilah jawaban yang diserahkan Bab 9.

Kasus Medikara: Tiga Aturan Tertulis

PRADITA University

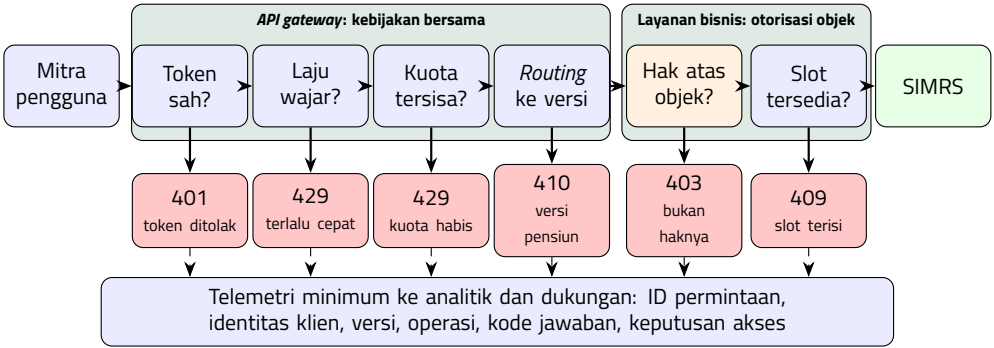
- Klinik baru langsung memakai versi 2. Pemakai versi 1 hanya boleh turun.
- Misalkan 3 klinik belum siap pada bulan ke-5: pendampingan 24 jam, Rp1,44 juta, lebih kecil daripada perpanjangan Rp3,75 juta.
- Perpanjangan satu kali, paling lama 1 bulan, alasan tertulis.
- Kerentanan serius: masa transisi dapat dipangkas menjadi 14 hari.
- Tanggal *sunset* ditulis di perjanjian kerja sama.

API Gateway

- Menerima permintaan dan menerapkan kebijakan bersama.
- *Routing*, pemeriksaan token, *rate limiting*, kuota, transformasi, pencatatan.
- Otorisasi objek dan aturan bisnis tetap di layanan.
- NIST SP 800-228: pola *hybrid*.
- Risiko *shared fate*: gangguan satu komponen mengenai semua API.

Analogi: pos memeriksa kartu tamu, tetapi petugas arsip menentukan berkas yang boleh dibaca.

Posisi Gateway pada Satu Permintaan



Fungsi Gateway dan Batasnya

PRADITA University

Fungsi	Pada API-01	Yang tidak diselesaikan
Routing	`/janji-temu` versi 1, `/v2/janji-temu` versi 2	Salah rute memutus semua mitra
Autentikasi	Token 15 menit dari Bab 6	Hak atas pasien tertentu
Rate limiting	Misalkan 1 per detik per klinik	Penarikan pelan dan lama
Kuota	300 per hari per klinik	Akses ke objek yang salah
Transformasi	Menambah `Deprecation` dan `Sunset`	Aturan bisnis tidak pindah ke sini
Pencatatan	Paling banyak 444.000 catatan per bulan	Tidak mencegah kejadian

Dua Contoh Berangka

PRADITA University

- Kebutuhan 195 panggilan per klinik per hari, kuota 300, sisa 105.
- Pola 155 panggilan per malam lolos kuota. Hanya hak atas objek yang menghentikannya.
- Misalkan salah konfigurasi 30 menit: 120 pemesanan klinik dan 56 Medikara+, atau 176.
- Diterapkan dulu pada 5 klinik uji: hanya 15 pemesanan.
- Perubahan kebijakan memerlukan pengujian dan cara pemulihan.

Batas Bukan Meteran

- Amazon API Gateway: kuota *best-effort*, target dan bukan batas atas yang dijamin.
- Penagihan klinik memerlukan catatan pemakaian yang direkonsiliasi.
- Beban rata-rata 11.160 panggilan per hari, sekitar 0,31 per detik.
- 40 klinik patuh 1 per detik dapat mencapai 40 per detik.
- Misalkan adaptor SIMRS sanggup 20 per detik: perlu batas kedua untuk seluruh API-01.

Menerapkan Kebijakan Keamanan Bab 6

PRADITA University

ID	Temuan Bab 6	Tempat utama	Tindakan
RA-01	Akun vendor membaca 140 tabel	*Gateway* dan layanan	Medikara+ hanya lewat API-01
RA-02	Hubungan layanan tidak diperiksa	Layanan bisnis	Hak atas objek
RA-03	12 sambungan tanpa pemilik	Katalog	Pemilik dicari lebih dulu
RA-04	Rekap 36 perusahaan lewat surel	Di luar *gateway*	Tetap antrean Bab 8
RA-05	Identitas 3 laboratorium tidak diuji	*Gateway*	Token per laboratorium
RA-06	Jawaban SATUSEHAT tidak diperiksa	Layanan pengirim	Arah keluar
RA-07	Kuota 300 belum diterapkan	*Gateway*	Kuota dan batas laju

Gateway memimpin 2 baris, membantu 1 baris, dan tidak menyelesaikan 4 baris.

Yang Sering Tertukar: Kebijakan dan Aturan Bisnis

PRADITA University

- Kebijakan lintas layanan berlaku sama untuk banyak API.
- Aturan bisnis perlu mengetahui slot, pasien, atau kontrak.
- Thoughtworks: *gateway* yang terlalu berambisi berada pada posisi *Hold*.
- Pembatalan 2 jam sebelum slot tidak ditulis di *gateway*.
- Kuota, laju, dan rute disimpan sebagai berkas yang ditinjau pemilik.

Kasus Medikara: Kebijakan Gateway API-01

PRADITA University

- Token di *gateway*. *Scope* dan hak atas objek di layanan.
- Per klinik 300 per hari dan 1 per detik, seluruh API-01 20 per detik.
- Telemetri minimum 90 hari, sekitar 666 MB, tanpa isi klinis.
- Satu *gateway* 99,9 persen: rantai 99,40 menjadi sekitar 99,30 persen, 168 menjadi 196 gagal per bulan.
- Dua salinan melindungi dari kerusakan mesin. Penerapan bertahap melindungi dari salah konfigurasi.

Komponen Platform Manajemen API

PRADITA University

Komponen	Pertanyaan yang dijawab	Contoh pada API-01
Gateway	Permintaan ini boleh diteruskan?	Token, laju, kuota, rute versi
Portal	Bagaimana mulai, apa yang berubah?	Panduan, kredensial uji, jadwal
Katalog	API apa, milik siapa, tahap apa?	Manajer Layanan Rawat Jalan
Analitik	Siapa memakai apa, berhasil atau tidak?	Pemakai versi 1 per klinik
Kebijakan	Aturan apa berlaku, siapa menyetujui?	Berkas kuota dan rute yang ditinjau

Data plane melayani permintaan. *Control plane* tempat kebijakan ditulis dan analitik dibaca. Analogi: pusat layanan tidak cukup berisi meja loket.

Dua Contoh Berangka

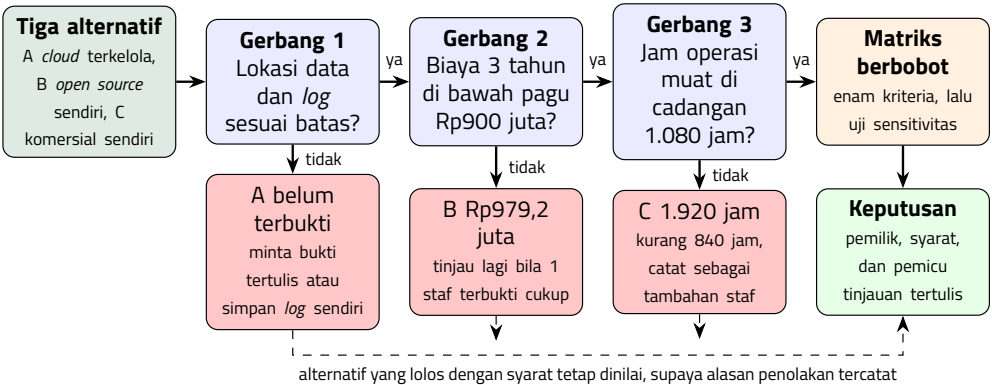
- Telemetri minimum: 444.000 catatan per bulan, sekitar 2,7 GB per tahun.
- Bila isi jawaban ikut dicatat: 266,4 GB, dan *log* menjadi salinan rekam medis.
- Misalkan *dashboard* mencatat 99 persen berhasil, tetapi telepon tetap 240 per hari.
- Janji nilai Rp172,8 juta per tahun belum terjadi.
- Pertanyaan arsitektur: identitas, aliran konfigurasi, data analitik, *control plane* gagal.

Memilih Platform: Enam Kriteria

- Biaya total, kebijakan, dukungan, lokasi data, portabilitas, keterampilan tim.
- *Open source* mengurangi lisensi, tetapi tetap memerlukan operasi.
- Layanan *cloud* mengalihkan operasi, tetapi menciptakan ketergantungan.
- Misalkan dua staf: 3.840 jam, Rp230,4 juta per tahun.
- UU 27/2022 Pasal 56: transfer bersyarat berjenjang. Data kesehatan: PP 28/2024 Pasal 966 dan 972.

Analogi: menyewa gedung dengan pengelola atau mengelola gedung sendiri. Harga diverifikasi saat keputusan.

Peta Keputusan Platform



Biaya Tiga Alternatif, 3 Tahun, Juta Rupiah

Komponen	A: *cloud* terkelola	B: *open source*	C: komersial
Lisensi atau langganan per tahun	180	0	96
Infrastruktur dan *log* per tahun	12	48	48
Staf operasi per tahun	57,6 (0,5 staf)	230,4 (2 staf)	115,2 (1 staf)
Kesiagaan per tahun	12	24	12
Penyiapan satu kali	24	72	48
Total 3 tahun	**808,8**	**979,2**	**861,6**
Terhadap pagu Rp900 juta	91,2 di bawah	79,2 di atas	38,4 di bawah
Terhadap cadangan 1.080 jam	Sisa 120 jam	Kurang 2.760 jam	Kurang 840 jam

Pemisalan latihan. Bila 1 staf cukup, B Rp633,6 juta. Bila trafik dua kali lipat, A Rp988,8 juta.

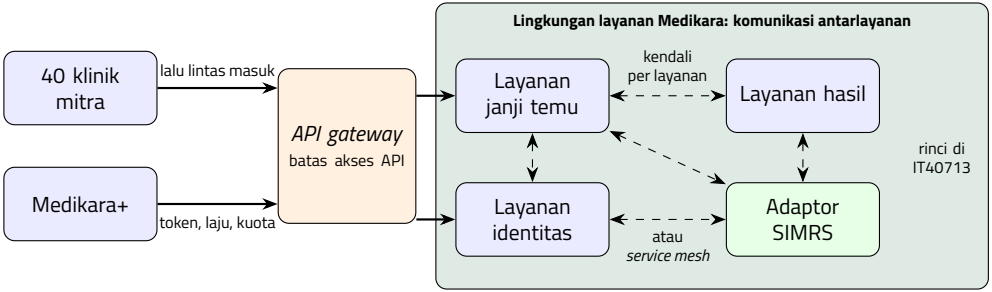
Matriks Berbobot

Kriteria	Bobot	A	B	C	Dasar skor
Biaya total	25	4	2	3	Tabel biaya
Kemampuan kebijakan	15	4	4	5	Token, kuota, rute versi
Dukungan	10	5	2	4	Janji layanan, eskalasi
Lokasi data	20	3	5	5	A belum punya bukti
Portabilitas	10	2	5	3	Kebijakan dapat dibawa
Keterampilan tim	20	4	2	3	Jam dan pengalaman
Nilai	**100**	**3,70**	**3,20**	**3,80**	Bobot kali skor, dibagi 100

Kasus Medikara: Memilih dari Selisih 0,10

- Skor lokasi A bernilai 3 karena buktinya belum ada. Dengan bukti, nilai A menjadi 3,90.
- Misalkan uji coba 2 minggu, 2 orang: 160 jam, Rp9,6 juta, pada A dan C.
- A pilihan bersyarat: lebih murah Rp52,8 juta dari C dan muat di cadangan jam.
- C cadangan bila bukti lokasi gagal. B ditolak, dengan pemicu tinjauan tertulis.
- Pagu Rp300 juta per tahun tetap. Rata-rata A Rp269,6 juta per tahun.

Dua Ruang Pengelolaan



API Gateway dan Service Mesh

PRADITA University

Unsur	*API gateway*	*Service mesh*
Ruang	Batas akses API	Komunikasi antarlayanan
Pertanyaan utama	Siapa mitra ini, seberapa banyak?	Layanan mana boleh memanggil?
Pemicu pada Medikara	API mitra pertama terbit	Misalkan lebih dari 60 layanan

- Misalkan cara sederhana Rp960.000 per layanan, *mesh* Rp57,6 juta. Titik impas 60 layanan.
- Pada 12 layanan, *mesh* lebih mahal Rp46,08 juta per tahun.
- Medikara memakai pola *hybrid*. Rincian Kubernetes dan *mesh* ada di IT40713.

Aktivitas: Rancangan Manajemen API

- Tujuan: rancangan manajemen API dan kebijakan siklus hidup untuk C3.
- Bisnis dan hukum: kebijakan versi dan pemberitahuan *deprecation*.
- Kesehatan atau akuntansi: dampak layanan dan biaya tiap pilihan.
- Teknis: posisi *gateway* dan aliran permintaan.
- Koordinator mencatat keputusan. Penelaah menantang asumsi.

Aktivitas: Langkah dan Luaran

- Tetapkan tahap API prioritas, lalu gambar posisi *gateway* dan layanan.
- Hitung masa transisi dari konsumen paling lambat, tulis pemberitahuan mitra.
- Bandingkan tiga alternatif: gerbang dulu, lalu matriks dan sensitivitas.
- Luaran: gambar, gerbang, jadwal, surat, matriks, keputusan, bukti.
- Kriteria: konsep 25, bukti 30, alasan 30, keterbacaan 15 persen.

Berkas pendukung: `sources/chapter10/README.md`

Ringkasan

- Satu API punya umur: lima tahap, empat gerbang, setiap tahap punya pemilik.
- *Deprecation* bukan *sunset*. Transisi dihitung dari konsumen paling lambat: 6 bulan.
- *Gateway* menjalankan kebijakan bersama. Otorisasi objek tetap di layanan.
- Platform dipilih dengan penyaring lalu matriks. Selisih 0,10 dapat dibalik satu bukti.
- *Gateway* dapat dibeli. Keputusan tentang siapa, sampai kapan, dan akibatnya tidak.

Latihan

1. Misalkan seorang mitra masih memakai API versi lama yang akan dipensiunkan. Susun langkah komunikasi dan tenggat yang adil bagi kedua pihak.
2. Jelaskan fungsi *API gateway* dengan analogi pos pemeriksaan, lalu sebutkan batas analogi tersebut.
3. Bandingkan layanan manajemen API dari penyedia *cloud* dengan produk *open source* yang dipasang sendiri, dari sisi biaya, kendali, dan keterampilan tim.